



Lecture 5

Incident Response and
Investigation

Defining an Incident

- In general, an incident is any event that has a negative effect on the confidentiality, integrity, or availability of an organization's assets.
- Notice that this definition encompasses events as diverse as direct attacks, natural occurrences such as a hurricane or earthquake, and even accidents, such as someone accidentally cutting cables for a live network.
- In contrast, a computer security incident (sometimes called just security incident) commonly refers to an incident that is the result of an attack or the result of malicious or intentional actions on the part of users.
- One of the primary goals of any security program is to prevent security incidents. However, despite the best efforts of IT and security professionals, incidents occur.
- When they do, an organization must be able to respond to limit or contain the incident. The primary goal of incident management is to minimize the impact on the organization.

Defining an Incident

- Organizations commonly define the meaning of a computer security incident within their security policy or incident management plans.
- The definition is usually one or two sentences long and includes examples of common events that the organization classifies as security incidents, such as the following:
 - Any attempted network intrusion
 - Any attempted denial-of- service attack
 - Any detection of malicious software
 - Any unauthorized access of data
 - Any violation of security policies

Incident Management Steps

- Effective incident management is handled in several steps or phases.
- The Figure shows the seven steps involved in incident management.
- It's important to realize that incident management is an ongoing activity, and the results of the lessons learned stage are used to improve detection methods or help prevent a repeated incident



Detection

- IT environments include multiple methods of detecting potential incidents.
- The following list identifies many of the common methods used to detect potential incidents. It also includes notes on how these methods report the incidents:
 - Intrusion detection and prevention systems send alerts to administrators when they detect a potential incident.
 - Antimalware software will often display a pop-up window to indicate when it detects malware.
 - Many automated tools regularly scan audit logs looking for predefined events, such as the use of special privileges. When they detect specific events, they typically send an alert to administrators.
 - End users sometimes detect irregular activity and contact technicians or administrators for help. When users report events, such as the inability to access a network resource or update a system, it alerts IT personnel about a potential incident.

Response

- After detecting and verifying an incident, the next step is response. The response varies depending on the severity of the incident.
- Many organizations have a designated incident response team—sometimes called a computer incident response team (CIRT) or computer security incident response team (CSIRT).
- The organization activates the team during a major security incident but does not typically activate the team for minor incidents.
- A formal incident response plan documents who would activate the team and under what conditions.
- Typically, team members investigate the incident, assess the damage, collect evidence, report the incident, and perform recovery procedures.
- They also participate in the remediation and lessons learned stages, and help with root cause analysis.

Reporting

- Reporting refers to reporting an incident within the organization and to organizations and individuals outside the organization.
- Organizations often have a legal requirement to report some incidents outside of the organization.
- Most countries have enacted regulatory compliance laws to govern security breaches, particularly as they apply to sensitive data retained within information systems.
- These laws typically include a requirement to report the incident, especially if the security breach exposed customer data.
- Laws differ from locale to locale, but all seek to protect the privacy of individual records and information, to protect consumer identities, and to establish standards for financial practice and corporate governance.

Recovery

- The next step is to recover the system or return it to a fully functioning state.
- This step can be very simple for minor incidents and may only require a reboot.
- However, a major incident may require completely rebuilding a system.
- Rebuilding the system includes restoring all data from the most recent backup.
- When a compromised system is rebuilt from scratch, it's important to ensure it is configured properly and is at least as secure as it was before the incident.
- If an organization has effective configuration management and change management programs, these programs will provide the necessary documentation to ensure the rebuilt systems are configured properly.

Remediation

- In the remediation stage, personnel look at the incident, identify what allowed it to occur, and then implement methods to prevent it from happening again. This step includes performing a root cause analysis.
- A root cause analysis examines the incident to determine what allowed it to happen.
 - For example, if attackers successfully accessed a database through a website, personnel would examine all the system elements to determine what allowed the attackers to succeed.
 - If the root cause analysis identifies a vulnerability that can be mitigated, this stage will recommend a change. Remediation steps might include implementing a patch management program.
 - Perhaps the website application wasn't using adequate input validation techniques, allowing a successful Structured Query Language (SQL) injection attack. Remediation would involve updating the application to include input validation.
 - Maybe the database is located on the web server instead of in a back-end database server. Remediation might include moving the database to a server behind an additional firewall.

Lessons Learned

- During the lessons learned stage, personnel examine the incident and the response to see if there are any lessons to be learned.
- The incident response team will be involved in this stage, but other employees who are knowledgeable about the incident will also participate.
- While examining the response to the incident, personnel look for any areas where they can improve their response.
 - For example, if the response team took a long time to contain the incident, the examination tries to determine why.
 - It might be that personnel don't have adequate training and didn't have the knowledge and expertise to respond effectively.
 - They may not have recognized the incident when they received the first notification, allowing an attack to continue longer than necessary. First responders may not have recognized the need to protect evidence and inadvertently corrupted it during the response.

Forensics

- Computer forensics is a very important topic for anyone involved in computer security or network administration.
- It is frequently the case that the first responder to a computer crime is the network administrator, not a law enforcement officer.
- And if you fail to handle the evidence properly, you may render it unusable in a court and ruin any chances of convicting the perpetrator.
- The field of computer forensics, now often called cyber forensics, attempts to apply forensic science to computer devices.
- Forensics is the process of using scientific knowledge for collecting, analyzing, and presenting evidence to the courts. (The word forensics means “to bring to the court.”)

Forensics

- Forensics deals primarily with the recovery and analysis of latent evidence. Latent evidence can take many forms, from fingerprints left on a window to DNA evidence recovered from blood stains to the files on a hard drive.
- The goal of cyber forensics is to examine computer devices (laptops, servers, cell phones, tablets, and so on) using scientific methods to extract evidence in such a way that such evidence can be presented in a court.
- There are certainly times when you will use forensics in scenarios that will never go to court. But the techniques were designed to satisfy the evidentiary requirements of courts.

Artifacts, Evidence Collection, and Forensic Procedures

- Collecting digital evidence is a tricky process and should be attempted only by professional forensic technicians. The International Organization on Computer Evidence (IOCE) outlines six principles to guide digital evidence technicians as they perform media analysis, network analysis, and software analysis in the pursuit of forensically recovered evidence:
 - When dealing with digital evidence, all of the general forensic and procedural principles must be applied.
 - Upon seizing digital evidence, actions taken should not change that evidence.
 - When it is necessary for a person to access original digital evidence, that person should be trained for this purpose.
 - All activity relating to the seizure, access, storage, or transfer of digital evidence must be fully documented, preserved, and available for review.
 - An individual is responsible for all actions taken with respect to digital evidence while the digital evidence is in their possession.
 - Any agency that is responsible for seizing, accessing, storing, or transferring digital evidence is responsible for compliance with these principles.

General Guidelines

- Don't Touch the Suspect Drive
 - The first, and perhaps most important, precaution is to touch the system as little as possible.
 - You do not want to make changes to the system in the process of examining it.
 - Let's look at one possible way to make a forensically valid copy of a drive. Some of this depends on Linux commands.
 - You will need a bootable copy of Linux. Any Linux live CD will do. You will actually need two copies: one on the suspect machine and one on the target machine.

General Guidelines

- You have to completely wipe the target drive:
`dd if=/dev/zero of=/dev/hdb1 bs=2048`
- Now you need to set up that target forensics server to receive the copy of the suspected drive you wish to examine. The netcat command helps with that:
`nc -l -p 8888 > evidence.dd`
- Here you are telling the machine to listen on port 8888 and put whatever it receives into evidence.dd.
- On the suspect machine, you have to start sending the drive's information to the forensics server:
`dd if=/dev/hda1 | nc 192.168.0.2 8888 -w 3`
- This assumes that the suspect drive is hda1. This also assumes the server has an IP address of 192.168.0.2.

General Guidelines

- You will also want to create a hash of the suspect drive. Later you can hash the drive you have been working with and compare that to the hash of the original drive and confirm that nothing has been altered.
- You can make a hash using Linux shell commands:
`md5sum /dev/hda1 | nc 192.168.0.2 8888 -w 3`
- When you are done, you have a copy of the drive.
- It is often a good idea to make two copies: One you will work with, and another will simply be stored. But in no case do you do your forensic analysis on the suspect drive.
- Other forensic tools: Forensic Toolkit and the FTK Imager, OSForensics, EnCase, Sleuth Kit (open source).

Can You Ever Conduct Forensics on a Live Machine?

- We have emphasized, and rightfully so, that whenever possible you should always create an image of the drive and perform the analysis only on that image.
- For a long time this was considered the only way to conduct computer forensics.
- However, the past few years have yielded some variation on that thinking. There are times when live forensics is possible or even desirable:
 - When you find a machine running, you should conduct some analysis of running processes, memory, and so on before shutting it down.
 - It may be necessary on clouds and clusters.
 - When the machine has already been imaged, thus preserving evidence.
 - When there is not a true forensic investigation, but rather asking a single question.
 - Be careful shutting down; if the machine has drive encryption, then when you boot it back up you won't be able to retrieve data.

Document Trail

- Beyond not touching the actual drive, the next issue is documentation.
- If you have never worked in an investigative capacity, the level of documentation may seem onerous to you. But the rule is simple: Document everything.
- When you first discover a computer crime, you must document exactly what events occurred.
 - Who was present, and what were they doing?
 - What devices were attached to the computer, and what connections did it have over the network/Internet?
 - What hardware was being used, and what operating system?
- Then when you begin your actual forensic investigation you must document every step.
- Start with documenting the process you use to make a forensic copy. Then document every tool you use, every test you perform. You must be able to show in your documentation everything that was done.

Secure the Evidence

- First and foremost, the computer must be taken offline to prevent further tampering. Now, there are some limited circumstances where a machine would be left online to trace down an active, ongoing attack. But the general rule is to take it offline immediately.
- The next step is to limit access to the machine. No one who does not absolutely need access to the evidence should have it. Hard drives should be locked in a safe or secure cabinet. Analysis should be done in a room with limited access.
- You must also be able to document who had access to the evidence, how they interacted with it, and where the evidence was stored.
- There must be no period of time that you cannot account for the evidence. This is called chain of custody.

Chain of Custody

- The concept of chain of custody is one of the cornerstones of forensic science, whether that is cyber forensics or some other forensic discipline.
- Chain of custody refers to detailed documentation showing the status of evidence at every point in time from the moment of seizure to the moment the evidence is presented in court.
- Any break in that chain of custody will likely render that evidence inadmissible at trial.
- According to the Scientific Working Group on Digital Evidence Model Standard Operation Procedures for Computer Forensics: "The chain of custody must include a description of the evidence and a documented history of each evidence transfer."
- This means that any time evidence is transferred from one location to another or from one person to another, that transfer must be documented.
- The first transfer is the seizure of evidence when the evidence is transferred to the investigator. Between that point in time and any trial, there may be any number of transfers.

FBI Forensics Guidelines

- If an incident occurs, the FBI recommends that the first responder preserve the state of the computer at the time of the incident by making a backup copy of any logs, damaged or altered files, and of course any files left by the intruder.
- Hackers frequently use various tools and may leave traces of their presence.
- Furthermore, the FBI warns that if the incident is in progress, activate any auditing or recording software you might have available.
- Collect as much data about the incident as you can. In other words, this might be a case where you do not take the machine offline but rather analyze the attack in progress.

FBI Forensics Guidelines

- Another important step is to document the specific losses suffered due to the attack. Losses typically include the following:
 - Labor cost spent in response and recovery.
 - The cost of the equipment if equipment was damaged.
 - The value of the data if any was lost or stolen. How much did it cost to obtain that data, and how much will it cost to reconstruct it?
 - Any lost revenue, including losses due to downtime, having to give customers credit due to inconvenience, or any other way in which revenue was lost.

FBI Forensics Guidelines

- The FBI computer forensic guidelines stress the importance of securing evidence. The FBI also stresses that you should not limit your concept of computer evidence to PCs and laptops. Computer evidence can include the following:
 - Logs (system, router, chat room, IDS, firewall)
 - Portable storage devices (USB drives, external drives)
 - Emails
 - Devices capable of storing data, such as iPod, iPad, and tablets
 - Cell phones

EU Evidence Gathering

- The Council of Europe Convention on Cybercrime, also called Budapest Convention on Cybercrime or simply Budapest Convention, refers to electronic evidence as evidence that can be collected in electronic form of a criminal offence.
- The EU also has five principles that establish a basis for all dealings with electronic evidence:
 - Principle 1: Data Integrity: You must ensure that the data is valid and has not been corrupted.
 - Principle 2: Audit trail: Similar to the concept of chain of custody, you must be able to fully account for the evidence. That includes its location as well as what was done with it.
 - Principle 3: Specialist support: As needed, utilize specialists. For example, if you are a skilled forensic examiner but have limited experience with a Macintosh computer, get a Mac specialist should you need to examine a Mac.
 - Principle 4: Appropriate training: All forensic examiners and analysts should be fully trained and always expanding their knowledge base.
 - Principle 5: Legality: Make certain all evidence is collected and handled in a manner consistent with all applicable laws.

Finding Evidence on The PC

- Finding Evidence in the Browser
 - The browser can be a source of both direct evidence and circumstantial or supporting evidence.
 - You may also find direct evidence in the case of cyber stalking.
 - However, if you suspect someone of creating a virus that infected a network, you would probably only find indirect evidence such as the person having searched virus creation/programming-related topics.
 - Even if the person erases his history, it is still possible to retrieve it. Windows stores a lot of information (such as web addresses, search queries, and recently opened files) in a file called index.dat.
 - Most forensics tools can extract a wide range of evidence from a computer.

Finding Evidence in System Logs

- Windows Logs

- With Windows, you find the logs by clicking on the Start button in the lower-left corner of the desktop and then clicking the Control Panel.
- You then click on Administrative Tools and the Event Viewer. Here are the logs you would check for (though not all of them appear in every version of Windows):
 - Security log: This is probably the most important log from a forensics point of view. It has both successful and unsuccessful login events.
 - Application log: This log contains various events logged by applications or programs. Many applications will record their errors here in the application log.
 - System log: The System log contains events logged by Windows system components. This includes events like driver failures. This particular log is not as interesting from a forensics perspective as the other logs are.

Finding Evidence in System Logs

- ForwardedEvents log: The ForwardedEvents log is used to store events collected from remote computers. This will only have data in it if event forwarding has been configured.
- Applications and Services logs: This log is used to store events from a single application or component rather than events that might have systemwide impact.
- However, with Windows systems, you have an additional possible concern. It is possible that the attacker cleared the logs before leaving the system.
- There are tools that will allow one to wipe out a log. It is also possible to simply turn off logging before an attack and turn it back on when you are done.
- One such tool is auditpol.exe. There are also tools, like WinZapper, that allow you to selectively remove certain items from event logs in Windows.

Finding Evidence in System Logs

- Linux Logs
 - Depending on your Linux distribution and the services you have running on it (like MySQL), some of these logs may not be present on a particular machine:
 - /var/log/faillog: This log file contains failed user logins. This can be very important when tracking attempts to crack into the system.
 - /var/log/kern.log: This log file is used for messages from the operating system's kernel. This is not likely to be pertinent to most computer crime investigations.
 - /var/log/lpr.log: This is the printer log and can give you a record of any items that have been printed from this machine. That can be useful in corporate espionage cases.
 - /var/log/mail.*: This is the mail server log and can be very useful in any computer crime investigation. Emails can be a component in any computer crime and even in some noncomputer crimes such as fraud.
 - /var/log/mysql.*: This log records activities related to the MySQL database server and will usually be of less interest to a computer crime investigation.

Finding Evidence in System Logs

- `/var/log/apache2/*`: If this machine is running the Apache web server, then this log will show related activity. This can be very useful in tracking attempts to hack into the web server.
- `/var/log/lighttpd/*`: If this machine is running the Lighttpd web server, then this log will show related activity. This can be very useful in tracking attempts to hack into the web server.
- `/var/log/apport.log`: This records application crashes. Sometimes these can reveal attempts to compromise the system or the presence of a virus or spyware.
- `/var/log/user.log`: These contain user activity logs and can be very important to a criminal investigation.

Getting Back Deleted Files

- It is a fact that criminals frequently attempt to destroy evidence.
- This is also true with computer crimes: Criminals may delete files.
- However, there are a variety of tools you can use to recover such files, particularly in Windows.
- DiskDigger is a free tool that can be used to recover Windows files. This is a very easy-to-use tool.
- There are more robust tools, but the fact that this is free and easy to use makes it perfect for students learning forensics.

The Windows Registry

- The Windows Registry is an incredible repository of potential valuable forensics information. It is the heart of the Windows machine.
- Microsoft describes the Registry as follows:
 - A central hierarchical database used in the Microsoft Windows family of Operating Systems to store information necessary to configure the system for one or more users, applications and hardware devices.
- The registry contains information that Windows continually references during operation, such as profiles for each user, the applications installed on the computer and the types of documents that each can create, property sheet settings for folders and application icons, what hardware exists on the system and the ports that are being used.

The Windows Registry

- The Registry is organized into five sections referred to as hives. Each of these sections contains specific information that can be useful to you. The five hives are described here:
 - HKEY_CLASSES_ROOT (HKCR): This hive stores information about drag and drop rules, program shortcuts, the user interface, and related items.
 - HKEY_CURRENT_USER (HKCU): This hive is very important to any forensic investigation. It stores information about the currently logged-on user, including desktop settings and user folders.
 - HKEY_LOCAL_MACHINE (HKLM): This hive can also be important to a forensic investigation. It contains those settings common to the entire machine, regardless of the individual user.
 - HKEY_USERS (HKU): This hive is very critical to forensics investigations. It has profiles for all the users, including their settings.
 - HKEY_CURRENT_CONFIG (HCU): This hive contains the current system configuration. This might also prove useful in your forensic examinations.

The Windows Registry

- USB Information
 - One of the first things most forensic analysts learn about the Windows Registry is that they can find out what USB devices have been connected to the suspect machine.
 - The Registry key `HKEY_LOCAL_MACHINE\System\ControlSet\Enum\USBSTOR` lists USB devices that have been connected to the machine.
 - It is often the case that a criminal will move evidence to an external device and take it with him.
 - This could indicate to you that there are devices you need to find and examine.
 - This Registry setting will tell you about the external drives that have been connected to this system.

Mobile Forensics: Cell Phone Concepts

- What are general principles that help you determine what to look for in a cell phone or other mobile device? Items you should attempt to recover from a mobile device include the following:
 - Details of the phone itself
 - Call history
 - Photos and video
 - GPS information
 - Network information
- Information about the phone should be one of the first things you document in your investigation.
- Just as you would document the specifics of a PC (model, operating system, and so on) you were examining, you should also document the phone or tablet specifics.
- This will include model number, serial number of the SIM card, operating system, and more. The more descriptive information you can document, the better.

Mobile Forensics: Cell Phone Concepts

- The call history will let you know who the user has spoken to and for how long.
- Obviously, call records by themselves are not sufficient to prove most crimes.
- With the exception of stalking or breaking a restraining order, just showing that one person called another is not enough to prove a crime. However, it can begin to build a circumstantial case.
- Photos and videos can provide direct evidence of a crime.
- GPS information has become increasingly important in a variety of cases.
- GPS cannot confirm that a suspect committed a crime, but it can show that the suspect was at a location where a crime was committed. Of course, GPS can also help to exonerate someone.

Mobile Forensics: Cell Phone Concepts

- Network information is also important. What Wi-Fi networks does the phone recognize?
- This might indicate where the phone has been. If a phone has connected to a coffee shop that is near the scene of a crime, it at least shows the perpetrator was in the area.
- It is also possible that traditional computer crimes, such as denial of service (DoS) and SQL injection, might trace back to a public Wi-Fi point, and the perpetrator was clever enough to mask his computer's identity.
- If you can show that his cell phone GPS was connected to that Wi-Fi, it will help establish he had the opportunity to commit the crime.